

Configurazione Audit Login/Logoff in Windows

Visualizzatore eventi, Criteri di sicurezza locali, analisi via PowerShell

1. Obiettivo e contesto del lab

In questo esercizio ho configurato l'auditing degli eventi di accesso e disconnessione su una macchina Windows 11, ho generato eventi di logon reali (sia riusciti che falliti) e li ho estratti dal registro Sicurezza tramite PowerShell. L'obiettivo formativo dichiarato dal lab Epicode era limitato all'apertura del Visualizzatore eventi e all'impostazione del log Login/Logoff: ho deciso di estendere l'esercizio includendo l'analisi via PowerShell, perche' nella pratica di un SOC Analyst i log non si leggono mai dalla GUI ma attraverso query filtrate e correlate.

Cosa significa: un sistema Windows senza policy di audit attiva non lascia traccia dei tentativi di accesso. Per un analista difensivo questa e' la prima configurazione da verificare quando si entra su un host: senza eventi 4624 e 4625, qualsiasi attivita' di brute force o di credential stuffing passa invisibile.

2. Ambiente di lavoro

Componente	Configurazione
Sistema operativo	Windows 11 Pro (host fisico, non VM)
Console di policy	secpol.msc (Criteri di sicurezza locali)
Console di lettura log	eventvwr.msc (Visualizzatore eventi)
Shell di analisi	Windows PowerShell elevato (Esegui come amministratore)
Registro analizzato	%SystemRoot%\System32\Winevt\Logs\Security.evtx
Utente di test	Account utente locale (identificativo oscurato per pubblicazione)



Cyber Security & Ethical Hacking
Esercizio

Esercizio di oggi: Creazione e Gestione delle Regole per i File di Log della Sicurezza in Windows

Obiettivo: Configurare e gestire i file di log della sicurezza utilizzando il Visualizzatore eventi di Windows.

Istruzioni:

- 1) Accedere al Visualizzatore Eventi:
 - a) Apri il Visualizzatore eventi premendo **Win + R** per aprire la finestra "Esegui".
 - b) Digita **eventvwr** e premi **Invio**.
- 2) Configurare le Proprietà del Registro di Sicurezza:
 - a) Nel pannello di sinistra, espandi "Registri di Windows" e seleziona "Sicurezza".
- 3) Provate a impostare il log dei Login/Logoff

Figura 1: traccia dell'esercizio Epicode fornita in aula.

3. Attivazione dell'auditing di Login/Logoff

Cosa ho fatto: ho aperto secpol.msc e ho navigato a Configurazione avanzata criteri di controllo > Criteri di controllo del sistema > Accesso/fine sessione. Su tre sottocategorie (Controlla Accesso, Controlla Fine sessione, Controlla Altri eventi di accesso/fine sessione) ho attivato sia Esito positivo che Esito negativo. Ho poi forzato l'aggiornamento dei criteri:

```
gpupdate /force
```

Perche' ho scelto la policy avanzata e non quella legacy: i Criteri locali tradizionali (Criteri locali > Criteri di controllo) offrono una sola voce monolitica Controlla eventi di accesso. La policy avanzata invece scompone l'auditing in undici sottocategorie indipendenti, consentendo per esempio di tracciare i logon ignorando il rumore dei servizi. E' la configurazione che si usa in produzione, perche' permette di calibrare il volume del log Sicurezza e di non saturare lo storage degli eventi.

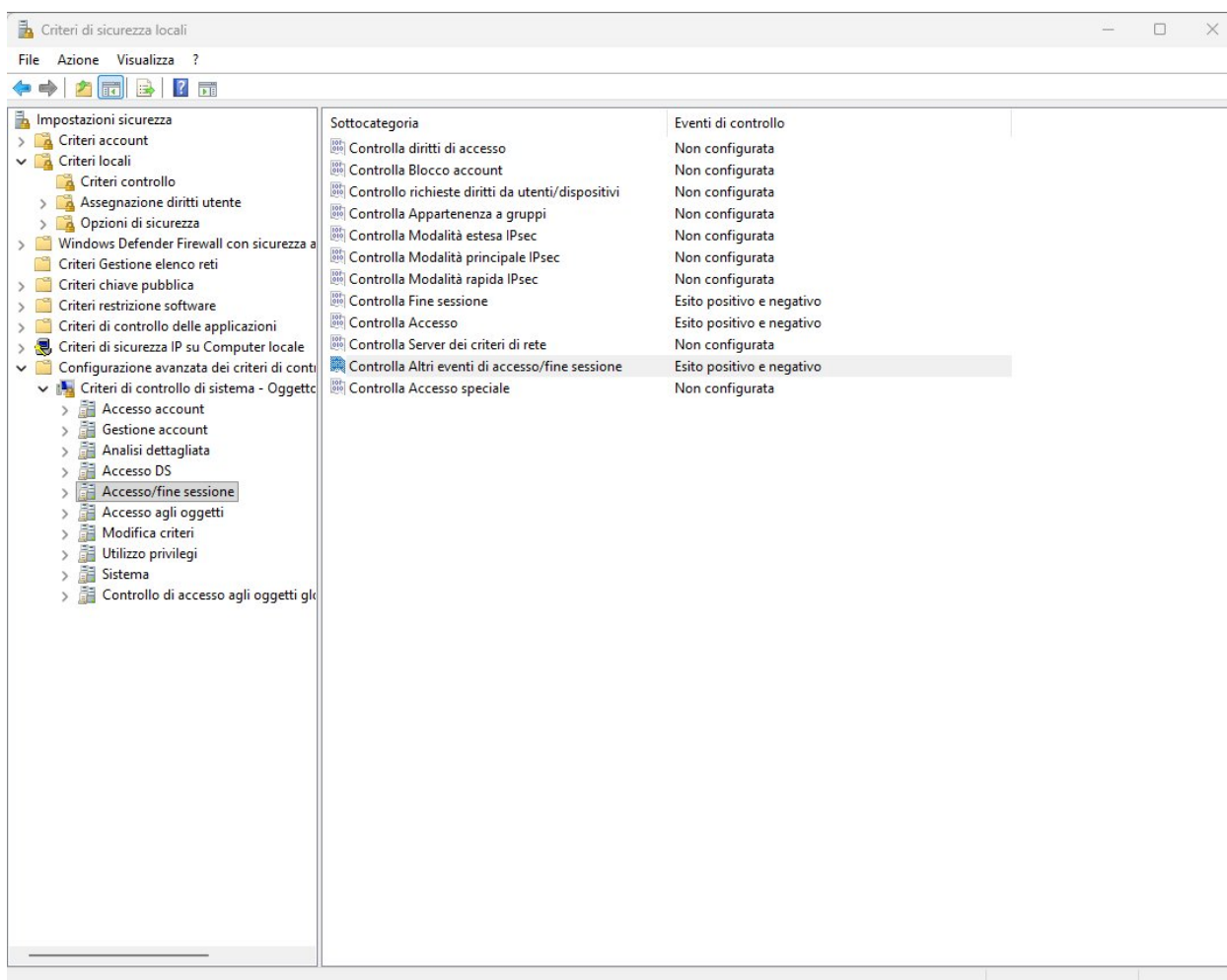


Figura 2: tre sottocategorie di Accesso/fine sessione attivate con esito positivo e negativo.

Cosa significa: dal momento in cui ho cliccato Applica, ogni evento di logon, disconnessione, sblocco workstation o utilizzo di credenziali esplicite viene scritto nel registro Sicurezza con un Event ID specifico, indipendentemente dall'esito.

4. Verifica indiretta: l'evento 4719

Cosa ho osservato: aprendo subito il Visualizzatore eventi su Registri di Windows > Sicurezza, ho trovato una raffica di eventi 4719 - Audit Policy Change tutti registrati nell'istante esatto in cui ho salvato secpol. Ogni sottocategoria abilitata produce un 4719 separato per Success e uno per Failure, quindi il volume osservato (oltre 20 voci concentrate in un secondo) e' coerente con le modifiche fatte.

[illegible]

Perche' e' importante: il 4719 e' uno degli eventi piu' monitorati in ambito SOC. Se un attaccante con privilegi locali tentasse di disabilitare l'auditing per coprire le proprie tracce, prima di sparire genererebbe comunque un 4719 con esito di disabilitazione. Le regole SIEM tipiche allertano su qualsiasi 4719 fuori orario o non correlato a un cambio di configurazione pianificato. Vedere 4719 nel mio log conferma che l'auditing e' attivo e registra anche le modifiche a se' stesso.

5. Generazione di eventi di logon controllati

Perche' questo passaggio era necessario: la sessione attiva sulla macchina era stata iniziata prima di aver abilitato l'auditing. Per definizione, Windows non registra retroattivamente: nessun evento 4624 esisteva relativo al mio logon originale. Senza lock/unlock il registro avrebbe contenuto solo logon di servizi SYSTEM.

6. Analisi del log via PowerShell

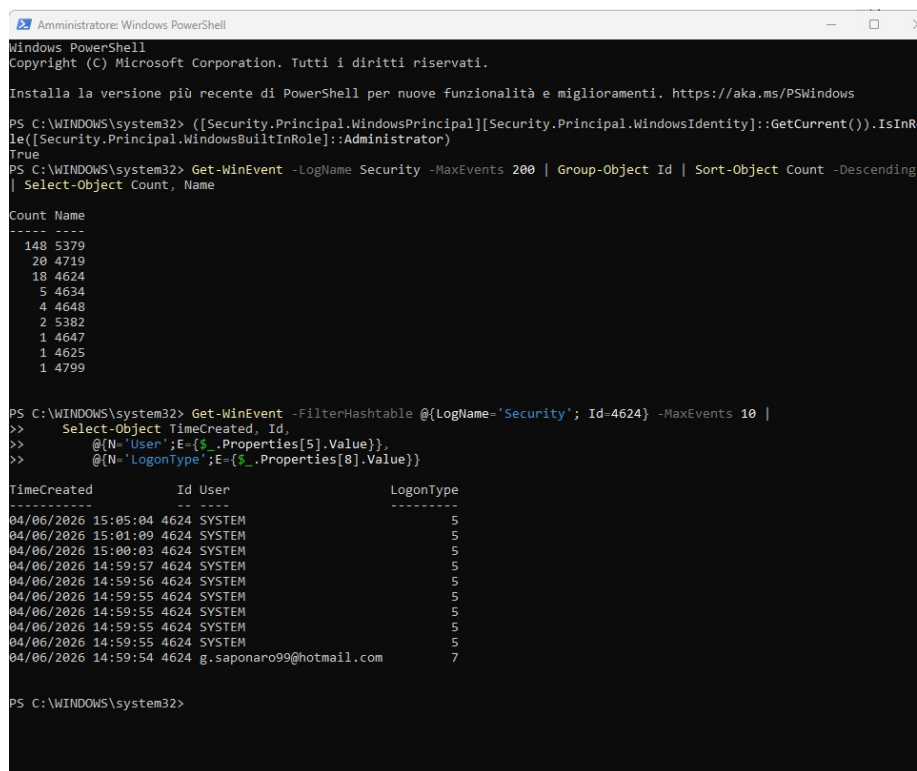
Prerequisito: il registro Sicurezza in Windows non e' leggibile da un utente non elevato. Ho aperto PowerShell con privilegi di amministratore e ho verificato il contesto di esecuzione:

```
([Security.Principal.WindowsPrincipal][Security.Principal.WindowsIdentity]::GetCurrent()  
)).  
IsInRole([Security.Principal.WindowsBuiltInRole]::Administrator)  
True
```

6.1 Distribuzione degli Event ID

Cosa ho fatto: ho aggregato gli ultimi 200 eventi del log Sicurezza per Event ID, in modo da avere una panoramica numerica di cio' che il sistema stava registrando.

```
Get-WinEvent -LogName Security -MaxEvents 200 |  
Group-Object Id | Sort-Object Count -Descending |  
Select-Object Count, Name
```



```
Windows PowerShell  
Copyright (c) Microsoft Corporation. Tutti i diritti riservati.  
  
Installa la versione più recente di PowerShell per nuove funzionalità e miglioramenti. https://aka.ms/PSWindows  
  
PS C:\WINDOWS\system32> ([Security.Principal.WindowsPrincipal][Security.Principal.WindowsIdentity]::GetCurrent()).IsInRole([Security.Principal.WindowsBuiltInRole]::Administrator)  
True  
PS C:\WINDOWS\system32> Get-WinEvent -LogName Security -MaxEvents 200 | Group-Object Id | Sort-Object Count -Descending |  
Select-Object Count, Name  
  
Count Name  
-----  
148 5379  
20 4719  
18 4624  
5 4634  
4 4648  
2 5382  
1 4647  
1 4625  
1 4799  
  
PS C:\WINDOWS\system32> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624} -MaxEvents 10 |  
>> Select-Object TimeCreated, Id,  
>> @('User';E-{$_.Properties[5].Value}),  
>> @('LogonType';E-{$_.Properties[8].Value})  
  
TimeCreated Id User LogonType  
-----  
04/06/2026 15:05:04 4624 SYSTEM 5  
04/06/2026 15:01:09 4624 SYSTEM 5  
04/06/2026 15:00:03 4624 SYSTEM 5  
04/06/2026 14:59:57 4624 SYSTEM 5  
04/06/2026 14:59:56 4624 SYSTEM 5  
04/06/2026 14:59:55 4624 SYSTEM 5  
04/06/2026 14:59:55 4624 SYSTEM 5  
04/06/2026 14:59:55 4624 SYSTEM 5  
04/06/2026 14:59:55 4624 SYSTEM 5  
04/06/2026 14:59:54 4624 g.saponaro99@hotmail.com 7  
  
PS C:\WINDOWS\system32>
```

Figura 4: distribuzione degli Event ID sugli ultimi 200 eventi del log Sicurezza.

Lettura della distribuzione:

Count	Event ID	Significato
148	5379	Lettura credenziali da Credential Manager (rumore di sistema)
20	4719	Modifica della policy di audit (salvataggio di secpol.msc)
18	4624	Logon riusciti, inclusi quelli dei servizi SYSTEM
5	4634	Disconnessione (logoff) di una sessione
4	4648	Logon con credenziali esplicite (es. runas o servizi)
2	5382	Recupero credenziali da Credential Manager
1	4647	Logoff iniziato dall'utente

Count	Event ID	Significato
1	4625	Logon fallito, il bersaglio interessante
1	4799	Enumerazione di un gruppo locale (Administrators)

6.2 Query mirata sui logon riusciti (4624)

Cosa ho fatto: ho filtrato il registro per ID 4624 escludendo i LogonType di servizio (5) e mantenendo solo i logon utente reali. Ho aggiunto una colonna descrittiva per il LogonType così da rendere la lettura immediata senza dover ricordare a memoria la tabella.

```
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624} -MaxEvents 50 |
Where-Object { $_.Properties[8].Value -in 2,7,10,11 } |
Select-Object TimeCreated, Id,
@{N='User';E={$_.Properties[5].Value}},
@{N='LogonType';E={$_.Properties[8].Value}},
@{N='LogonTypeDesc';E={
switch($_.Properties[8].Value){
2 {'Interactive'}; 7 {'Unlock'};
10 {'RemoteInteractive (RDP)'}; 11 {'CachedInteractive'}
}
}}
```

```
PS C:\WINDOWS\system32> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624} -MaxEvents 50 |
>> Where-Object { $_.Properties[8].Value -in 2,7,10,11 } |
>> Select-Object TimeCreated, Id,
>> @{N='User';E={$_.Properties[5].Value}},
>> @{N='LogonType';E={$_.Properties[8].Value}},
>> @{N='LogonTypeDesc';E={
>>     switch($_.Properties[8].Value){
>>     2 {'Interactive'}; 7 {'Unlock'}; 10 {'RemoteInteractive (RDP)'}; 11 {'CachedInteractive'}
>>     }
>> }}

TimeCreated : 04/06/2026 14:59:54
Id           : 4624
User         : 
LogonType    : 7
LogonTypeDesc : Unlock

TimeCreated : 04/06/2026 14:59:54
Id           : 4624
User         : 
LogonType    : 7
LogonTypeDesc : Unlock

TimeCreated : 04/06/2026 14:59:54
Id           : 4624
User         : 
LogonType    : 11
LogonTypeDesc : CachedInteractive

TimeCreated : 04/06/2026 14:59:54
Id           : 4624
User         : 
LogonType    : 11
LogonTypeDesc : CachedInteractive

TimeCreated : 04/06/2026 14:59:42
Id           : 4624
User         : DWM-9
LogonType    : 2
LogonTypeDesc : Interactive

TimeCreated : 04/06/2026 14:59:42
Id           : 4624
User         : DWM-9
LogonType    : 2
LogonTypeDesc : Interactive

TimeCreated : 04/06/2026 14:59:42
Id           : 4624
User         : UMF-9
LogonType    : 2
LogonTypeDesc : Interactive

TimeCreated : 04/06/2026 14:38:27
Id           : 4624
User         : 
LogonType    : 7
LogonTypeDesc : Unlock

TimeCreated : 04/06/2026 14:38:27
Id           : 4624
User         : 
LogonType    : 7
LogonTypeDesc : Unlock

TimeCreated : 04/06/2026 14:38:27
Id           : 4624
User         : 
LogonType    : 11
LogonTypeDesc : CachedInteractive

TimeCreated : 04/06/2026 14:38:27
Id           : 4624
User         : 
LogonType    : 11
LogonTypeDesc : CachedInteractive
```

Figura 5: output filtrato dei logon 4624, con due cluster di Unlock/CachedInteractive per il mio utente.

Lettura: i logon piu' significativi sono quelli con il mio account utente (identificativo oscurato negli screenshot per OPSEC) e LogonType 7 (Unlock), accompagnati sempre da un LogonType 11 (CachedInteractive) generato un attimo prima. La coppia 11 + 7 e' il comportamento canonico di Windows allo sblocco: prima valida le credenziali cached della sessione, poi sblocca la workstation. Gli utenti DWM-9 e UMFD-9 visibili come Interactive non sono umani: sono account di sistema generati per il Desktop Window Manager e l'User Mode Font Driver, e in un'analisi reale vanno filtrati via.

6.3 Query sui logon falliti (4625)

Cosa ho fatto: ho estratto l'unico 4625 presente nel log, prestando attenzione al fatto che lo schema dell'evento ha indici di Properties diversi rispetto al 4624.

```
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} |
Select-Object TimeCreated, Id,
@{N='TargetUser';E={$_.Properties[5].Value}},
@{N='LogonType';E={$_.Properties[10].Value}},
@{N='FailureReason';E={$_.Properties[8].Value}},
@{N='Status';E={$_.Properties[7].Value}}
```

```
PS C:\WINDOWS\system32> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} |
>> Select-Object TimeCreated, Id,
>>     @{N='TargetUser';E={$_.Properties[5].Value}},
>>     @{N='LogonType';E={$_.Properties[10].Value}},
>>     @{N='FailureReason';E={$_.Properties[8].Value}},
>>     @{N='Status';E={$_.Properties[7].Value}}
```

```
TimeCreated      : 04/06/2026 14:59:51
Id                : 4625
TargetUser        : -
LogonType          : 2
FailureReason      : %%2304
Status            : -1073741715
```

Figura 6: il 4625 generato dal tentativo con password errata, tre secondi prima del successo.

Decodifica del risultato:

Campo	Valore osservato	Interpretazione
TimeCreated	04/06/2026 14:59:51	Tre secondi prima del 4624 di Unlock riuscito alle 14:59:54
LogonType	2	Interactive: tentativo dalla tastiera locale, coerente con uno sblocco
Status	-1073741715	Rappresentazione signed di 0xC000006D = STATUS_LOGON_FAILURE: password errata
FailureReason	%%2304	Placeholder localizzato Windows: 'An error occurred during Logon'

Cosa significa in chiave difensiva: un singolo 4625 isolato seguito da un 4624 dello stesso utente entro pochi secondi e' il pattern di una semplice digitazione errata della password. Non genera allarme. Lo scenario diventa critico quando si osservano N tentativi consecutivi di 4625 sullo stesso TargetUser senza un 4624 finale, soprattutto se provenienti da indirizzi IP remoti via LogonType 3 (network) o 10 (RDP): in quel caso si sta guardando un brute force o un password spray. Le regole SIEM tipiche correlano in finestre di 5-15 minuti, con soglie attorno ai 5-10 fallimenti per utente.

7. Tabella di riferimento per l'analisi

Riassumo qui gli Event ID che ho incontrato in questo lab e che ritrovero' in qualsiasi esercizio di triage su host Windows.

Event ID	Significato	LogonType / nota chiave
4624	Logon riuscito	2 interattivo, 3 rete (SMB), 7 unlock, 10 RDP, 11 cached
4625	Logon fallito	Status 0xC000006D password errata, 0xC0000064 utente inesistente
4634	Logoff (terminazione sessione)	Generato automaticamente quando la sessione si chiude
4647	Logoff iniziato dall'utente	Affiancato al 4634 nel caso di logoff esplicito
4648	Logon con credenziali esplicite	Tipico di runas, scheduled task con account diverso
4672	Privilegi speciali assegnati	Indica un logon con privilegi amministrativi
4719	Modifica policy di audit	Sempre monitorato in ottica anti-tampering
4799	Enumerazione gruppo locale	Rumore in volumi bassi, sospetto a raffica
5379	Lettura Credential Manager	Rumore di sistema, alto volume fisiologico

8. Conclusioni

Ho portato a termine la configurazione richiesta dal lab e ho verificato che l'auditing sia operativo a tre livelli indipendenti: la policy salvata in secpol, la presenza dei 4719 generati dalla policy stessa, e la cattura di eventi 4624 e 4625 corrispondenti ad azioni che ho generato manualmente sulla mia macchina.

L'esercizio mi ha permesso di consolidare tre nozioni che ritengo centrali per un ruolo junior in ambito SOC: primo, l'auditing in Windows non e' attivo per default e va sempre verificato come baseline; secondo, l'analisi seria di un log Sicurezza si fa via Get-WinEvent e non in GUI, perche' solo la prima permette filtraggio, normalizzazione e correlazione; terzo, il valore di un Event ID e' contestuale e va sempre letto in relazione al LogonType, allo Status e alla finestra temporale degli eventi vicini.

Per i prossimi passi vorrei integrare questo flusso con un forwarder verso Wazuh o Splunk in laboratorio, in modo da passare dalla raccolta locale alla centralizzazione e iniziare a scrivere regole di correlazione sopra gli stessi Event ID.